

ADR-04 — Implementación de autenticación basada en JWT

Estado

Propuesto

Contexto

El sistema **ERP Iglesias** está compuesto por un **frontend Angular** y un **backend REST API**.

Actualmente los sistemas web modernos requieren mecanismos de autenticación seguros que permitan:

- proteger los endpoints del backend
- controlar el acceso de los usuarios al sistema
- mantener sesiones seguras entre cliente y servidor
- escalar el sistema sin depender de sesiones almacenadas en el servidor

En arquitecturas modernas basadas en **APIs REST**, una práctica común es utilizar **JSON Web Tokens (JWT)** para gestionar la autenticación.

Problema

Si el sistema no implementa un mecanismo adecuado de autenticación:

- cualquier cliente podría consumir la API
- no existiría control de acceso a los recursos
- las sesiones dependerían de almacenamiento en el servidor
- el sistema sería más difícil de escalar

Además, en arquitecturas SPA como Angular, los mecanismos tradicionales basados en sesiones de servidor no son la opción más adecuada.

Decisión Arquitectónica

Se propone implementar **autenticación basada en JSON Web Tokens (JWT)**.

El flujo de autenticación será el siguiente:

```
Usuario inicia sesión
↓
Frontend envía credenciales al backend
```

```
↓  
Backend valida usuario  
↓  
Backend genera JWT  
↓  
Frontend almacena el token  
↓  
Frontend envía JWT en cada petición  
↓  
Backend valida el token
```

Arquitectura de autenticación:

```
Angular Frontend  
↓  
Authentication API  
↓  
Generación de JWT  
↓  
Cliente envía token en cada request  
↓  
Backend valida JWT
```

Patrón de Diseño Aplicado

Token-Based Authentication Pattern

Este patrón utiliza tokens firmados digitalmente para autenticar solicitudes entre cliente y servidor.

Principio SOLID Aplicado

Single Responsibility Principle (SRP)

El sistema separa responsabilidades:

- módulo de autenticación → gestión de usuarios y generación de tokens
 - controladores del sistema → manejo de lógica de negocio
 - middleware de seguridad → validación de tokens
-

Cambio Concreto Propuesto

Se implementará autenticación basada en JWT para proteger los endpoints del sistema.

El proceso incluirá:

1. endpoint de autenticación
2. generación del token JWT
3. almacenamiento del token en el cliente
4. envío del token en cada petición HTTP

Ejemplo de Flujo de Autenticación

Login del usuario

```
POST /api/auth/login
```

Body:

```
{
  "username": "user",
  "password": "password"
}
```

Respuesta del servidor

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9..."
}
```

Uso del token en peticiones

Las peticiones posteriores incluirán el token en el header:

```
Authorization: Bearer <token>
```

Beneficios Arquitectónicos

La autenticación basada en JWT proporciona:

- mayor seguridad en el acceso a la API

- arquitectura **stateless** compatible con REST
- escalabilidad del sistema
- separación clara entre autenticación y lógica de negocio
- facilidad para integrar clientes web o móviles

Impacto en el Sistema

La implementación de JWT permitirá proteger los recursos del sistema y controlar el acceso de los usuarios.

Este cambio no afecta la funcionalidad principal del sistema, pero mejora significativamente la seguridad y la arquitectura del backend.

Resultado Arquitectónico

Arquitectura final propuesta:

```
Usuario
↓
Angular Frontend
↓
API Authentication
↓
Generación JWT
↓
Cliente envía token
↓
Backend valida token
```

Este enfoque permite implementar un sistema de autenticación moderno, seguro y escalable para el ERP.